

# Re-Auditoria Técnica — ERPOS V2 (estado pós-correções)

**Data:** 2026-06-10 **Auditor:** Revisão externa (somente leitura — nenhum arquivo, função SQL ou dado foi alterado)  
**Projeto Supabase:** mdghhj em zdm eu q p z u y z x **Escopo:** PDV/Caixa, Autoatendimento, QR Code/Mesa, Gestão de Pedidos, Relatórios, Estoque + configurações que impactam esses módulos. **Método:** leitura do código atual (frontend React + Edge Functions Deno), inspeção direta de RPCs/enums/constraints/índices e advisors de segurança do Postgres.

Esta é uma **segunda passada completa** sobre o sistema, depois que os bugs da auditoria anterior foram enviados ao gerador (readdy.ai) e corrigidos. O objetivo aqui é triplo: (1) confirmar o que foi corrigido na fonte, (2) caçar **bugs novos** — inclusive os que as próprias correções possam ter introduzido, (3) varrer áreas antes não auditadas a fundo (sync offline, vouchers, PIX, a nova fila de status, a nova numeração).

## VEREDITO RÁPIDO

O sistema deu um salto grande de maturidade. Os bloqueadores que reprovavam a versão anterior — **segurança de RPC, RLS, estorno falso, pagamento fantasma, pedido duplicado, estoque não devolvido** — foram **todos corrigidos e verificados na fonte**. Hoje **não há mais nenhum bloqueador crítico em aberto** no escopo auditado. Restam itens de **severidade média/baixa** (a maioria operacional ou contábil de refinamento) e **4 achados novos** desta passada, sendo o mais relevante de natureza **condicional** (segurança do webhook PIX, quando o PIX entrar em produção). Veredito de produção na Seção 6.

## 1. MAPA DA ARQUITETURA (estado atual)

Sem mudança estrutural relevante: React 19 + Vite + 22 contexts + ~60 hooks → Edge Functions Deno (order-write, mesa-write, table-write, stock-write, financial-write, production-write, kiosk-auth, pix-payment, ...) → RPCs SECURITY DEFINER → Postgres (Supabase) + Realtime + agente local de impressão.

**Novidades de infraestrutura introduzidas pelas correções (todas verificadas):** - Tabela tenant\_day\_order\_seq (tenant\_id, day, last\_number) + RPC fn\_next\_tenant\_order\_number → numeração por tenant/dia. - orders.client\_request\_id com UNIQUE index → idempotência de criação de pedido. - orders.out\_for\_delivery\_at + ação mark\_out\_for\_delivery → "Em Rota" persistente. - order\_items.unit\_cost → snapshot de custo para CMV. - Fila de retry de status no KDS persistida em sessionStorage (pendingStatusQueue). - Auto-expiração de lock de edição (5 min) em checkOrderLock.

## 2. MAPA DE DEPENDÊNCIAS

Inalterado em relação à auditoria anterior. Pontos de concentração de risco (single points of failure) continuam: order-write (arquivo único grande), fn\_record\_payment\_bypass (toda receita), fn\_next\_tenant\_order\_number (toda numeração), deductStockForOrderItem/buildDeductions (toda baixa de estoque). Todos hoje com tratamento mais robusto (idempotência, bloqueio de pagamento sem caixa, restock baseado em movimentos reais).

## 3. MATRIZ DE RISCOS (estado atual)

| Severidade | Item em aberto                                                                                                                                                                                                                                                                                                                                                        |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CRÍTICO    | (nenhum no escopo auditado)                                                                                                                                                                                                                                                                                                                                           |
| ALTO       | NEW-02 (webhook PIX sem autenticação — condicional: só importa quando o PIX/Demon for ativado)                                                                                                                                                                                                                                                                        |
| MÉDIO      | BUS-09 (numeração reseta à meia-noite), NEW-01 (voucher double-spend concorrente), BUS-28 (baixa de estoque depende de marcação no KDS)                                                                                                                                                                                                                               |
| BAIXO      | BUS-42 (DRE-cassa inclui cartão a prazo), BUS-43 (base de cartão a prazo fora do fluxo), BUS-29 (G/VC - 30) está conectada a uma guarda interna travada, BUS-29 (plano consumo se ficha mal movimenta), BUS-24 (foto modelo de mesa convergente), NEW-03 (pedido offline preso em "syncing" após crash), NEW-04 (re-sync offline registra pagamento sem idempotência) |

## 4. LISTA DE BUGS

### 4.1 Confirmados CORRIGIDOS (verificados na fonte)

| ID              | Título                                        | Como foi confirmado                                                                                                                                |
|-----------------|-----------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| BUG-01          | RPCs admin destrutivas abertas a anon         | Guarda interna em <code>fn_admin_*</code> :<br><code>service_role ok, authenticated só admin, ELSE RAISE EXCEPTION 'anon calls are blocked'</code> |
| BUG-02          | <code>hr_payroll</code> RLS desligada         | Advisors: <b>0 erros</b> (eram 4); RLS habilitada                                                                                                  |
| BUG-03          | RLS vouchers via <code>user_metadata</code>   | Advisor <code>rls_references_user_metadata</code> eliminado                                                                                        |
| BUG-04          | Estorno falso (senha 1234)                    | <code>EstornoModal</code> removido; botão usa <code>CancelamentoModal</code> real ( <code>fn_cancel_and_refund_order</code> )                      |
| BUG-05          | Pagamento não-bloqueante / pago sem payment   | <code>record_payment</code> retorna erro <code>no_cash_register; is_paid</code> calculado de <code>payments</code> reais                           |
| BUG-06          | Pedido duplicado por retry                    | <code>client_request_id</code> + UNIQUE index + checagem idempotente (cobre também o sync offline)                                                 |
| BUG-07          | Restock não devolvia adicionais               | <code>fn_restock_order</code> reverte os <code>theoretical_out</code> reais (cobre adicionais)                                                     |
| BUG-09/38       | "Em Rota" não persistia                       | Ação <code>mark_out_for_delivery + out_for_delivery_at</code> + fila de retry                                                                      |
| BUG-10          | Autoatendimento offline perdia pedido         | Usa <code>saveOfflineOrder</code> (IndexedDB) + auto-sync + badge                                                                                  |
| BUG-12          | Receita dobrada em split                      | <code>fin_cash_flow</code> usa <code>paymentAmount</code> (não o total do pedido)                                                                  |
| BUG-13          | Fallback do relatório de caixa zerava         | Fallback reconstrói <code>cash_transactions</code> dos <code>payments</code> reais                                                                 |
| BUG-15          | Fidelidade contada em dobro                   | Incremento removido do caminho "entregue"; só no <code>record_payment</code>                                                                       |
| BUG-16          | Promoções em UTC                              | <code>nowTimeMinutesBrasilia()</code> / <code>todayDayOfWeekBrasilia()</code>                                                                      |
| BUG-17          | <code>current_uses</code> nunca incrementado  | <code>fn_increment_promotion_uses</code> no <code>record_payment</code>                                                                            |
| BUG-18          | Restock inflava estoque                       | Restock baseado nos <code>theoretical_out</code> reais (não na ficha)                                                                              |
| BUG-19          | Fechar caixa com pendências                   | <code>FecharSessaoModal</code> chama <code>check-session-pending</code> e bloqueia                                                                 |
| BUG-20          | Bucket <code>menu-images</code> listável      | Advisor eliminado                                                                                                                                  |
| BUG-21          | Estoque negativo mascarado                    | <code>fn_update_ingredient_stock</code> sem <code>GREATEST(0,...)</code>                                                                           |
| BUG-23          | <code>participant_name</code> morto           | Usado em <code>destination_name</code> no mesa-write                                                                                               |
| BUG-24          | Mesa "fail-open"                              | Não assume sessão aberta em erro de rede                                                                                                           |
| BUG-27          | Reembolso em dinheiro fora do caixa           | Cria <code>cash_movements</code> type="out" (sangria)                                                                                              |
| BUG-30          | Custo de produção fora do CMV                 | <code>fn_register_production_and_stock_v2</code> atualiza <code>unit_price</code> da saída                                                         |
| BUG-31          | Ajuste de inventário sem sinal                | <code>inventory_adjustment</code> respeita o sinal de <code>p_quantity</code>                                                                      |
| BUG-32          | CMV ignorava combos/adicionais                | <code>fn_get_cmv_report</code> cobre <code>combo_ingredients</code> e <code>order_item_options</code>                                              |
| BUG-33          | Combo direto + subitens                       | <code>buildDeductions</code> processa as duas fontes                                                                                               |
| BUG-34          | CMV com preço atual retroativo                | <code>order_items.unit_cost</code> (snapshot) usado pelo CMV                                                                                       |
| BUG-35/36/37    | Fase não persistia / lock preso               | Fila de retry persistida + flush online/polling + lock auto-expira 5 min                                                                           |
| BUG-39/40/41/44 | Financeiro (fontes/regime/duplicação/estorno) | Visão Geral lê <code>fin_cash_flow</code> ; DRE-Competência não soma "a receber"; <code>payments</code> filtra <code>is_refunded</code>            |

## 4.2 Em aberto (re-confirmados)

### BUG-08 — Numeração reseta à meia-noite (precisa ser por "dia operacional")

- **Severidade:** MÉDIA · **Módulo:** Pedidos/Numeração · **Tipo:** Banco / Regra de negócio
- **Evidência:** `fn_next_tenant_order_number` usa `v_day := to_char(NOW() AT TIME ZONE 'America/Sao_Paulo', 'DDMMYY')` e a tabela `tenant_day_order_seq (tenant_id, day)`. Resolve a colisão entre terminais/sessões simultâneos (bom), **mas reseta a sequência para 0001 à meia-noite de calendário**.
- **Como reproduzir:** Restaurante abre sábado 18:00 e atende até domingo 02:00 com o mesmo expediente. À meia-noite a sequência volta para 0001 enquanto a cozinha ainda produz pedidos da mesma noite.
- **Impacto:** Cozinha (que olha os últimos dígitos) vê "0001" reaparecer no meio da operação; a mesma noite fica partida em duas datas.
- **Sugestão:** Numerar por **dia operacional** com corte configurável (ex.: 05:00), não por calendário. *(Prompt detalhado já entregue ao cliente.)*

### BUG-28 — Baixa de estoque depende de marcação no KDS

- **Severidade:** MÉDIA · **Tipo:** Regra de negócio / Usabilidade
- **Evidência:** A baixa (`theoretical_out`) ocorre quando o item vira `ready/delivered` (exceção: `skip_kds` na criação). Operação que não usa o KDS com disciplina não decrementa estoque.
- **Sugestão:** Opção configurável de baixar no pagamento.

### BUG-42 — DRE-"Caixa" inclui cartão a prazo ainda não recebido

- **Severidade:** BAIXA · **Evidência:** O DRE-caixa (`DRETab.tsx`) ainda soma `payments` por `created_at`, incluindo cartão `days_to_receive>0`. **Sugestão:** reconhecer cartão a prazo só no recebimento.

### BUG-43 — Taxa de cartão a prazo não entra no fluxo de caixa

- **Severidade:** BAIXA · **Evidência:** A taxa (`auto_card_fee`) só é lançada em `fin_cash_flow` no ramo `days_to_receive===0`. (O DRE compensa recalculando ao vivo.)

### BUG-25 — `exec_sql` ainda concedido a anon/authenticated

- **Severidade:** BAIXA (defesa em profundidade) · **Evidência:** `has_function_privilege('anon', ...)` = true; a guarda interna (`current_user NOT IN (...)`) bloqueia o uso, mas o grant deveria ser revogado.

### BUG-29 / BUG-14 — modelagem de produção / dois modelos de mesa

- **Severidade:** BAIXA · Sem validação que impeça ficha de prato com insumos crus que já são receita de produção (BUG-29); mesa-QR aproximou-se do modelo "table" mas a unificação total não foi confirmada (BUG-14).

## 4.3 Achados NOVOS desta passada

### NEW-01 — Resgate de voucher: read-then-write sem trava → double-spend concorrente

- **Severidade:** MÉDIA · **Módulo:** Vouchers · **Tipo:** Backend / Concorrência / Financeiro
- **Evidência técnica:** Em `voucher-write` ação `redeem_voucher`, o saldo é lido (`voucher.current_balance`), comparado com `amount` e gravado com `newBalance = current_balance - amount` em chamadas separadas

([voucher-write/index.ts:280-301](#)). Não há `SELECT ... FOR UPDATE` nem decremento atômico condicional.

- **Como reproduzir:** Dois resgates simultâneos do mesmo voucher (mesmo código usado em dois terminais/abas): ambos leem saldo 50, ambos passam na checagem e debitam 30 → 60 gastos de um voucher de 50.
- **Resultado esperado:** Decremento atômico (`UPDATE ... SET current_balance = current_balance - amount WHERE current_balance >= amount` retornando linha afetada).
- **Impacto:** Perda financeira por uso além do saldo do voucher. Também não é idempotente em retry de rede.
- **Sugestão:** Tornar o débito atômico/condicional em uma única instrução, ou usar `FOR UPDATE`.

## NEW-02 — Webhook de confirmação PIX sem autenticação/validação de assinatura (condicional)

- **Severidade:** ALTA (condicional — só impacta quando o PIX/Stone for ativado em produção) · **Módulo:** Pagamentos/PIX · **Tipo:** Segurança
- **Evidência técnica:** `pix-payment` ação `confirm` ([pix-payment/index.ts:236-258](#)) marca `fin_pix_payments.status='confirmed'` filtrando apenas por `pix_payment_id/txid` com `status='pending'`. Não há verificação de assinatura/HMAC do provedor nem autenticação — qualquer um que conheça/adivinha um `txid` (`ERPOS{timestamp}{random5}`) pode marcar uma cobrança como paga.
- **Como reproduzir:** `POST` para a função com `{action:'confirm', txid:'...'}` sem credencial → PIX vira "confirmado". Se o fluxo de venda liberar o pedido ao ver `confirmed`, gera **venda sem pagamento real**.
- **Resultado esperado:** Validar a assinatura do webhook do provedor (Stone) antes de confirmar.
- **Impacto:** Em produção com PIX real, fraude de pagamento. (Atenuante: a confirmação é idempotente — `status='pending'` — e a integração Stone real pode ainda não estar ativa.)
- **Sugestão:** Exigir validação de assinatura/segredo do provedor no webhook.

## NEW-03 — Pedido offline pode ficar preso em 'syncing' após crash (órfão, sem retry)

- **Severidade:** BAIXA · **Módulo:** Offline · **Tipo:** Integração
- **Evidência técnica:** `syncSingleOrder` marca `status:'syncing'` antes de enviar ([offlineSync.ts:43](#)); `getPendingOrders` só retorna `status='pending'` ([offlineDB.ts:283](#)). Se a aba fechar/cair entre o `syncing` e o `synced/pending`, o pedido fica preso em `syncing` e **nunca é re-tentado**.
- **Impacto:** Pedido pode existir no servidor (criação é idempotente) mas o registro local fica órfão; se a queda foi antes dos pagamentos, o pedido fica sem pagamento. Baixa frequência.
- **Sugestão:** Recuperar 'syncing' antigos (timeout) no início do sync.

## NEW-04 — Re-sync offline registra pagamentos sem idempotência

- **Severidade:** BAIXA · **Módulo:** Offline · **Tipo:** Integração / Financeiro
- **Evidência técnica:** Em `syncSingleOrder`, a criação do pedido é idempotente (`client_request_id`), mas o loop de `record_payment` ([offlineSync.ts:87-104](#)) não tem chave de idempotência. Se um pedido já criado + pago fosse re-sincronizado, os pagamentos seriam reinseridos (duplicados).
- **Atenuante:** O comportamento órfão do NEW-03 hoje impede o re-sync nesse cenário, mas a ausência de idempotência em `record_payment` é uma fragilidade latente (vale também para o fluxo online).
- **Sugestão:** Idempotência em `record_payment` (ex.: chave por `order_id + payment_method_id + amount + sequência`).

# 5. RISCOS PARA PRODUÇÃO

**Nenhum bloqueador crítico em aberto no escopo auditado.** Antes de operar com PIX real, tratar **NEW-02** (autenticação do webhook). Para qualidade operacional/contábil, em ordem de prioridade prática:

1. **BUG-08** — corte de dia operacional na numeração (afeta a cozinha toda noite que vira a meia-noite).
2. **NEW-01** — débito atômico de voucher (evita double-spend).
3. **BUG-28** — desacoplar baixa de estoque da marcação no KDS (ou documentar o procedimento obrigatório).
4. **BUG-42 / BUG-43** — refinamento contábil de cartão a prazo (baixo impacto; DRE já compensa parte).
5. **BUG-25** — revogar `exec_sql` de anon (higiene).
6. **NEW-03 / NEW-04** — robustez do sync offline (baixa frequência).

---

## 6. CONCLUSÃO

---

"Eu colocaria esse sistema em produção hoje?"

**Sim** — para operação com pagamentos em dinheiro/cartão (sem PIX real), com um piloto controlado e acompanhamento de fechamento. A diferença em relação à auditoria anterior é grande: os defeitos que causavam **perda financeira, divergência de caixa, estoque inconsistente e perda de pedidos** foram corrigidos e **verificados na fonte** — incluindo os três bloqueadores de segurança, o estorno falso, o pagamento fantasma, o pedido duplicado e o restock incompleto. O núcleo transacional hoje está sólido e com defesas adequadas (idempotência, bloqueio de pagamento sem caixa, fila de retry de status, lock com expiração).

**Ressalvas técnicas:** - **Não ativar PIX real** sem antes corrigir **NEW-02** (webhook sem autenticação) — é o único achado de severidade alta, e é condicional ao uso de PIX. - **Corrigir o BUG-08** logo no início da operação se o restaurante costuma virar a meia-noite — é o item que mais aparece no dia a dia. - **NEW-01 (voucher)** deve ser tratado antes de promoções com voucher de saldo em escala.

Resumo: de "**não colocaria em produção**" (auditoria anterior) para "**colocaria em piloto controlado, sem PIX real, monitorando caixa e estoque**". A maturidade do sistema subiu de patamar.

---

*Re-auditoria somente-leitura. Nenhuma correção foi implementada, conforme solicitado.*